

Exercice 2 : cas pratique, la fuite de données de la DGFIP (été 2026)

Nom et Prénom : _____

1. Type d'attaque initiale

Les contribuables n'ont pas été hameçonnés. Le pirate est entré avec les identifiants de comptes internes, ceux d'un agent de la DGFIP et d'un tiers habilité. Le phishing se situe plus tôt dans la chaîne : d'après l'énoncé, ces identifiants auraient été volés par un infostealer, un malware souvent installé en ouvrant la pièce jointe ou le lien d'un e-mail piégé, et qui récupère les mots de passe et les sessions enregistrés dans le navigateur. La victime du phishing est donc l'agent, pas le contribuable. Il faut quand même rester prudent : la DGFIP confirme l'usurpation des identifiants, mais n'a pas dit publiquement comment ils ont été obtenus. Le ministre a toutefois annoncé davantage d'exercices de phishing pour les agents, ce qui va dans ce sens.

2. Mécanisme de l'attaque

Le pirate a d'abord récupéré les identifiants de l'agent, probablement grâce à un infostealer diffusé par phishing. Il s'est ensuite connecté aux outils internes des agents. Pour le système, c'était un utilisateur autorisé, ce qui explique que l'intrusion ait été difficile à repérer. Il s'est servi des droits de consultation de ces comptes pour interroger puis extraire en masse, hors des circuits habituels, les dossiers de 678 000 usagers (environ 350 000 particuliers et 250 000 professionnels). Les accès ont été fermés en juin et juillet 2026, mais le vol n'a été établi que le 12 août, après la revendication de ZeroBytes.

3. Données compromises et risques

Ces données viennent directement de l'administration : elles sont exactes et à jour. Elles regroupent au même endroit l'identité, les coordonnées (adresse, e-mail, téléphone), la situation financière (RFR, taux de prélèvement, situation familiale) et même la liste des échanges avec les impôts. Et contrairement à un mot de passe, on ne peut pas changer son revenu ou sa situation familiale après une fuite. Trois risques concrets pour les personnes touchées :

1. l'arnaque au faux conseiller, bancaire ou fiscal : l'escroc connaît le dossier de sa victime et s'en sert pour obtenir ses codes ou lui faire valider un virement ;
2. le phishing ciblé (faux remboursement, fausse régularisation) pour voler des coordonnées bancaires ou les identifiants impots.gouv.fr ;
3. l'usurpation d'identité (ouverture de comptes, crédits). Il faut en plus une copie de pièce d'identité, mais les données volées aident à l'obtenir.

4. Conséquences sur le phishing

Un phishing générique se repère assez facilement. Avec ces données, chaque message peut être personnalisé : vrai nom, identifiant fiscal, RFR, taux de prélèvement, voire l'objet d'un échange récent avec les impôts. La victime se dit que seule l'administration peut savoir tout ça et baisse la garde. L'attaquant peut aussi viser d'abord les foyers aux revenus élevés, caler ses envois sur les échéances fiscales et relancer par SMS ou par téléphone. La fuite elle-même devient un prétexte (« votre dossier a été compromis, vérifiez vos informations ici »). Côté entreprises, le SIREN et les métadonnées des échanges suffisent à rendre crédibles de fausses factures ou une fraude au président.

5. Mesures de protection

Pour les contribuables concernés :

1. Ne pas cliquer sur les liens reçus par e-mail ou SMS, et passer directement par impots.gouv.fr et sa messagerie sécurisée. Le courrier de la DGFIP sur l'incident ne contient d'ailleurs aucun lien et ne demande aucune information confidentielle.
2. Ne donner aucun code ni aucune coordonnée bancaire par téléphone, e-mail ou SMS, et signaler les tentatives : Signal Spam pour les e-mails, le 33700 pour les SMS, Phishing Initiative pour les faux sites, 17Cyber ou cybermalveillance.gouv.fr pour être aidé.
3. En cas de fraude, appeler sa banque tout de suite, garder les preuves, porter plainte (commissariat, gendarmerie ou plateforme THÉSÉE) et changer son mot de passe si on l'a communiqué.

Pour l'administration fiscale :

1. Contenir l'incident : fermer les comptes utilisés, couper par précaution les accès sensibles des agents et surveiller les modifications sur les comptes des contribuables touchés.
2. Notifier la CNIL (art. 33 du RGPD), prévenir chaque personne concernée (art. 34), porter plainte et travailler avec l'ANSSI.
3. Renforcer l'accès des agents : double authentification pour tous d'ici fin 2026, audit supervisé par l'ANSSI, meilleure détection des consultations anormales, plus d'exercices de phishing internes. Ces mesures ont été annoncées le 18 août et ne sont pas encore toutes en place.

Sources. Ministère de l'Économie, communiqué n° 953 (14/08/2026) ; DGFIP, page incident impots.gouv.fr (14/08/2026, m.à.j. 14/09/2026) ; DGFIP, FAQ particuliers et FAQ professionnels (24/08/2026) ; CNIL, *Piratage du système d'information des impôts* (18/08/2026) ; Cybermalveillance.gouv.fr, *Hameçonnage impôts* (m.à.j. 18/09/2026) ; ANSSI, *Recommandations relatives à l'authentification multifacteur* (2021) ; ACSC, *Information stealer malware* (2025) ; *Le Monde* (18/08 et 04/09/2026) ; *The Register* (14/08/2026).